

DEVOPS E ARQUITETURA CLOUD

FASE 3 | AULA 03 -

SEGURANÇA DE IDENTIDADE E ACESSO (IAM, MFA E ZERO TRUST)

SUMÁRIO

O QUE VEM POR AÍ?	3
HANDS ON	4
SAIBA MAIS	5
MERCADO, CASES E TENDÊNCIAS	19
O QUE VOCÊ VIU NESTA AULA?	20
REFERÊNCIAS.....	21

O QUE VEM POR AÍ?

Nesta aula, vamos explorar sobre um dos pilares fundamentais da segurança em cloud: a gestão de identidade e acesso. Um cenário onde o perímetro de segurança tradicional se dissolveu e os recursos estão distribuídos em ambientes multicloud e híbridos, garantir que apenas as pessoas autorizadas e sistemas corretos acessem os recursos certos, no momento adequado e pelas razões legítimas, tornou-se uma tarefa crítica e complexa.

Abordaremos os conceitos de Gerenciamento de Identidade e Acesso (IAM), Autenticação Multifator (MFA) e a arquitetura de Confiança Zero (Zero Trust), elementos que se combinam para formar uma defesa robusta contra ameaças cada vez mais sofisticadas.

Além disso, discutiremos a importância vital do MFA como uma camada adicional de proteção e como a filosofia "nunca confie, sempre verifique" do Zero Trust está remodelando a forma como concebemos a segurança em ambientes de nuvem.

HANDS ON

Nesta videoaula, vamos explorar a configuração de políticas de IAM em um provedor de cloud. A atividade consistirá em criar um usuário com permissões mínimas para acessar um serviço específico, aplicando o princípio do menor privilégio. Em seguida, habilitaremos a autenticação multifator (MFA) para este usuário, adicionando uma camada extra de segurança.

Utilizaremos a AWS como exemplo, mas os conceitos são transferíveis para outros provedores como Azure e Google Cloud. O primeiro passo é a criação de uma política de IAM customizada que concede acesso de leitura a um bucket S3 específico.

Após a criação da política, ela será associada a um novo usuário. Em seguida, configuraremos o MFA para este usuário. Este processo garantirá que, mesmo que as credenciais do usuário sejam comprometidas, o acesso não autorizado será impedido pela exigência de um segundo fator de autenticação.

SAIBA MAIS

Na aula anterior sobre o modelo de responsabilidade compartilhada, foi abordado como provedores de serviços em cloud e clientes dividem suas responsabilidades essenciais para manter dados e sistemas com segurança. Agora, nós avançamos para um dos pilares mais críticos, Segurança de Identidade e Acesso (IAM, MFA e Zero Trust).

No conteúdo desse material, nós vamos explorar como controlar quem pode acessar os recursos (e sobre qual condições), garantindo que identidades sejam devidamente protegidas. Nós vamos compreender como IAM (Identity and Access Management) organiza e aplica políticas de acesso, como a autenticação multifator (MFA) adiciona camadas de defesa contra acessos não autorizados e como o modelo Zero Trust quebra a lógica da confiança implícita, exigindo validação contínua para cada tentativa de acesso.

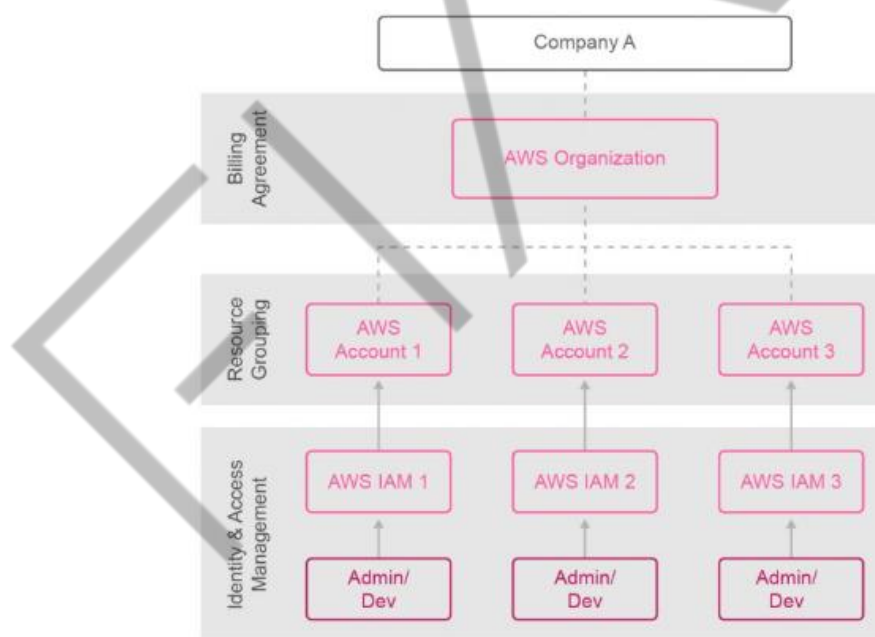


Figura 1 – Arquitetura de gerenciamento de identidade e acesso em ambientes em cloud.
Fonte: Microsoft Learning (2024)

O Gerenciamento de Identidade e Acesso representa uma mudança na forma como entendemos a segurança em ambientes em cloud. Tradicionalmente, as empresas dependiam de um modelo de segurança baseado em perímetro, onde a

confiança era estabelecida uma vez que um usuário ou dispositivo atravessasse o firewall corporativo. No entanto, a evolução para ambientes de cloud, híbrida e multicloud, combinada com o trabalho remoto e a expansão de dispositivos móveis, tornou o modelo obsoleto e perigoso.

Em ambientes de computação com a cloud, a identidade tornou-se o novo perímetro de segurança. Você pode ler o que a Cloud Security Alliance diz: "com as plataformas de nuvem consolidando inúmeras funções administrativas de data centers e serviços em consoles web e interfaces de programação de aplicativos (APIs) unificadas e acessíveis pela Internet, o IAM atua como o novo perímetro na segurança nativa da nuvem".

Esta transformação exige uma compreensão profunda não apenas dos mecanismos técnicos, mas também dos princípios estratégicos que governam o acesso a recursos digitais. Gartner define o Gerenciamento de Identidade e Acesso como uma disciplina de segurança que permite que os indivíduos certos acessem os recursos certos, nos momentos certos e pelas razões certas. Esta definição é simples e encapsula uma complexidade quando aplicada a ambientes corporativos. Vamos explicar cada elemento desta definição para compreender suas implicações práticas.

Primeiro, vamos falar sobre **Identidade Digital e Entidades**. Uma identidade digital é a representação eletrônica de uma entidade em um sistema computacional. Esta entidade pode ser um usuário humano, um dispositivo IoT, uma aplicação ou um serviço de microsserviços. Cada identidade é caracterizada por um conjunto único de atributos que a descrevem e a diferenciam de outras identidades no mesmo domínio de segurança.

Em ambientes de cloud com grandes complexidades, uma única entidade física pode ter múltiplas identidades, cada uma adaptada para contextos específicos de uso. Falando sobre **autenticação e verificação de identidade**: a autenticação é o processo fundamental de verificar se uma identidade é válida. Este processo vai muito além da simples verificação de credenciais como nome de usuário e senha. Em ambientes com segurança, a autenticação pode incorporar análise comportamental, geolocalização, análise de dispositivos e padrões de acesso históricos.

A autenticação forte requer múltiplos fatores de verificação, criando camadas de segurança que são exponencialmente mais difíceis de comprometer. Porém, agora

precisamos entender o que é o próximo a **Autorização**. Após a autenticação bem-sucedida, o sistema deve determinar quais ações a identidade autenticada tem permissão para executar.

A autorização é um processo dinâmico que considera não apenas a identidade do usuário, mas também o contexto da solicitação, incluindo o recurso sendo acessado, o momento do acesso, a localização, o dispositivo utilizado e o estado de segurança atual do ambiente.

Controle de Acesso: quem define a aplicação de políticas e o controle de acesso é o mecanismo responsável por implementar as decisões de autorização. Ele atua como um guardião digital, permitindo ou negando acesso com base nas políticas estabelecidas. Em ambientes cloud, este controle deve ser granular, dinâmico e capaz de operar em escala massiva.

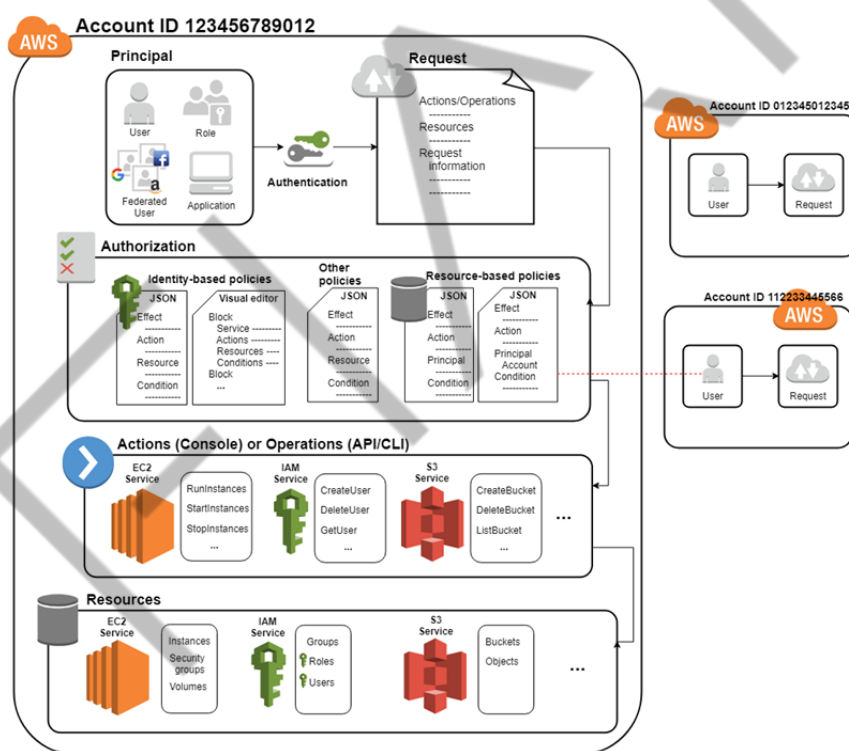


Figura 2 – Como a AWS funciona?

Fonte: AWS (2023)

Arquitetura de um sistema IAM robusto é composto por vários componentes interconectados e cada um tem seu papel crucial na segurança geral do sistema:

O primeiro é o **provedor de Identidade (Identity Provider - IdP)**. Trata-se do componente central responsável por autenticar usuários e emitir tokens de segurança.

Em ambientes corporativos, o IdP frequentemente integra-se com diretórios corporativos como Active Directory, LDAP.

Quando falamos de **Provedor de Serviços (Service Provider - SP)**, estamos nos referindo ao componente para qualquer aplicação ou serviço que confia no IdP para autenticação. Em ambientes cloud, isso pode incluir aplicações SaaS, plataformas de desenvolvimento, sistemas de banco de dados, ou qualquer recurso que requer acesso controlado.

Sobre o **Mecanismo de Políticas (Policy Engine)**, trata-se do componente que avalia as solicitações de acesso contra políticas definidas, considerando múltiplos fatores de contexto. O mecanismo de políticas é onde a lógica de negócio de segurança é implementada, permitindo decisões de acesso sofisticadas e dinâmicas.

O **repositório de atributos** é o componente que armazena informações contextuais sobre usuários, recursos e ambiente que são utilizados nas decisões de acesso. Pode incluir informações como cargo do usuário, departamento, classificação de dados, localização geográfica e estado de conformidade de dispositivos.

A evolução dos modelos de controle de acesso reflete a crescente demanda de evolução dos ambientes de TI. Lembra do RBAC (Role-Based Access Control), o modelo tradicional na gestão de acesso? O RBAC foi desenvolvido na década de 1990 como uma resposta às limitações dos modelos de controle de acesso (DAC) e obrigatório (MAC). No RBAC, as permissões são associadas a papéis (roles), e os usuários recebem acesso através da atribuição desses papéis. Este modelo oferece várias vantagens significativas em ambientes organizacionais estruturados.

A principal vantagem do RBAC é a sua simplicidade conceitual. Os administradores podem criar papéis que refletem funções das empresas reais, como "Desenvolvedor", "Gerente de Projeto", ou "Analista Financeiro". Quando um novo funcionário é contratado, simplesmente atribui-se o papel apropriado, e ele herda automaticamente todas as permissões necessárias para sua função. Similarmente, quando um funcionário muda de departamento, a transição de acesso pode ser gerenciada através da retribuição de papéis.

Mas, nem tudo é perfeito. O RBAC enfrenta desafios significativos em ambientes dinâmicos e complexos. O fenômeno conhecido como "explosão de papéis" ocorre quando empresas criam funções cada vez mais específicas para

atender a necessidades particulares, resultando em centenas ou milhares de papéis que se tornam difíceis de gerenciar. Além disso, o RBAC não é adequado para decisões de acesso que dependem de contexto dinâmico, como localização, horário ou estado de segurança do dispositivo.

Com isso, ocorre a evolução para um modelo que oferece flexibilidade e granularidade: o **ABAC** (Attribute-Based Access Control), que representa uma grande evolução no controle de acesso. Em vez de depender de papéis estáticos, o **ABAC** toma decisões de acesso baseadas em atributos de múltiplas dimensões: sujeito (usuário), objeto (recurso), ação e ambiente. Esta abordagem oferece flexibilidade e granularidade sem grandes desafios.

Os atributos do sujeito podem incluir informações como cargo, departamento, nível de autorização de segurança, localização atual e histórico de comportamento. Os atributos do objeto descrevem o recurso que está sendo acessado, incluindo classificação de dados, proprietário, sensibilidade e requisitos de conformidade.

Os atributos de ambiente capturam o contexto da solicitação, como horário, localização da rede, método de acesso e estado de segurança atual do sistema. A verdadeira potência do **ABAC** emerge quando estes atributos são combinados em políticas sofisticadas.

Por exemplo, uma política pode permitir que gerentes de projeto acessem dados financeiros de seus projetos durante horário comercial, a partir de dispositivos corporativos, localizados em escritórios da empresa. Esta mesma política pode automaticamente negar acesso se qualquer uma dessas condições não for atendida.

A implementação de **ABAC** requer planejamento cuidadoso da taxonomia de atributos e das políticas que os governam. A complexidade inicial pode ser significativa, mas os benefícios em termos de segurança e flexibilidade justificam o investimento, especialmente em ambientes em cloud onde o contexto de acesso é altamente variável.

Temos também o **PBAC** que pode ser visto como uma implementação específica do ABAC, onde as regras de acesso são codificadas em políticas legíveis por máquina. Estas políticas são frequentemente expressas em linguagens formais como XACML (eXtensible Access Control Markup Language), ou em formatos mais modernos como JSON ou YAML.

A principal vantagem do PBAC é a centralização da lógica de controle de acesso em políticas explícitas e auditáveis. As políticas podem ser versionadas, testadas e implantadas usando práticas de DevOps, trazendo rigor de engenharia para o gerenciamento de segurança.

O PBAC também habilita a automação avançada de decisões de acesso. Sistemas podem avaliar políticas complexas em tempo real, considerando centenas de atributos e regras para tomar decisões de acesso precisas e consistentes.

Nesse cenário, a federação de identidade é fundamental, pois possibilita que um mesmo conjunto de credenciais seja utilizado para acessar diferentes sistemas e serviços, eliminando a necessidade de criar e manter logins separados para cada aplicação. Isso não apenas simplifica a experiência do usuário, mas também fortalece a segurança ao reduzir os riscos relacionados à gestão fragmentada de credenciais.

Entre os padrões de federação mais utilizados está o Security Assertion Markup Language (SAML) 2.0, um framework maduro e amplamente adotado em ambientes corporativos. Baseado em XML, o SAML define como provedores de identidade e provedores de serviço trocam informações de autenticação e autorização, sendo a base para a implementação de Single Sign-On (SSO) em grande escala.

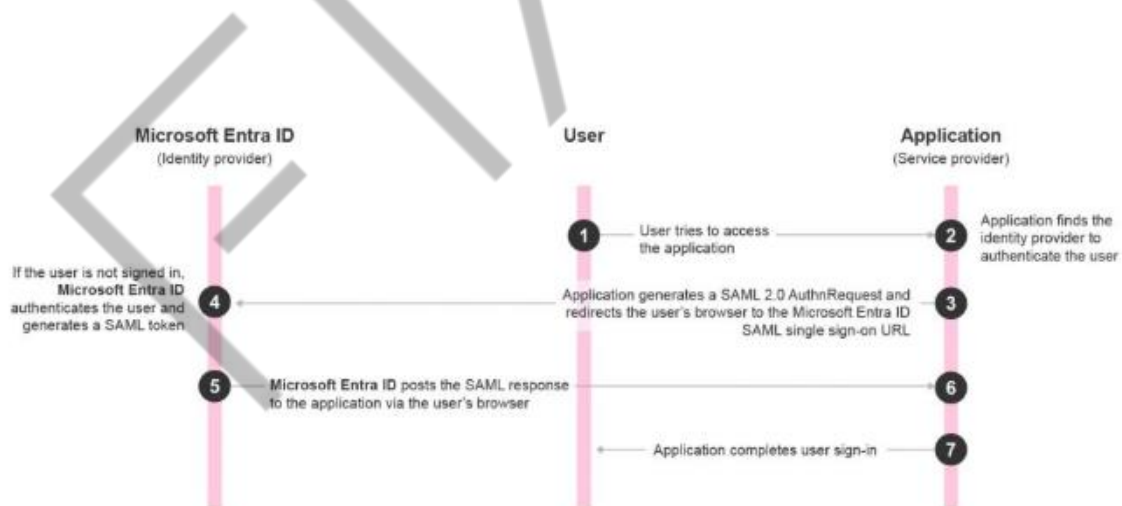


Figura 3 – Protocolo SAML de logon único – Microsoft identity platform
Fonte: Microsoft Learning (2022)

O protocolo SAML opera através de um processo de redirecionamento cuidadosamente orquestrado. Quando um usuário tenta acessar um recurso protegido, ele é redirecionado para o provedor de identidade para autenticação. Após autenticação bem-sucedida, o IdP gera uma "asserção SAML" - um documento XML

assinado digitalmente que contém informações sobre a identidade do usuário e seus atributos. Esta asserção é então enviada de volta ao provedor de serviço, que a valida e concede acesso apropriado.

As asserções SAML podem conter três tipos de declarações: declarações de autenticação (confirmando que o usuário foi autenticado), declarações de atributo (fornecendo informações sobre o usuário) e declarações de decisão de autorização (indicando se o usuário tem permissão para executar ações específicas).

A segurança do SAML depende criticamente de assinaturas digitais e, opcionalmente, criptografia. As asserções são assinadas pelo IdP usando sua chave privada, permitindo que os provedores de serviço verifiquem a autenticidade e integridade das informações. Para informações sensíveis, as asserções podem também ser criptografadas usando a chave pública do provedor de serviço.

Temos ainda o OAuth 2.0, que é Autorização Delegada. Ele é diferente do SAML em seu propósito e design. Enquanto o SAML é um protocolo de autenticação e autorização, o OAuth 2.0 é especificamente um framework de autorização delegada. Ele foi projetado para permitir que aplicações de terceiros obtenham acesso limitado aos recursos de um usuário sem expor suas credenciais.

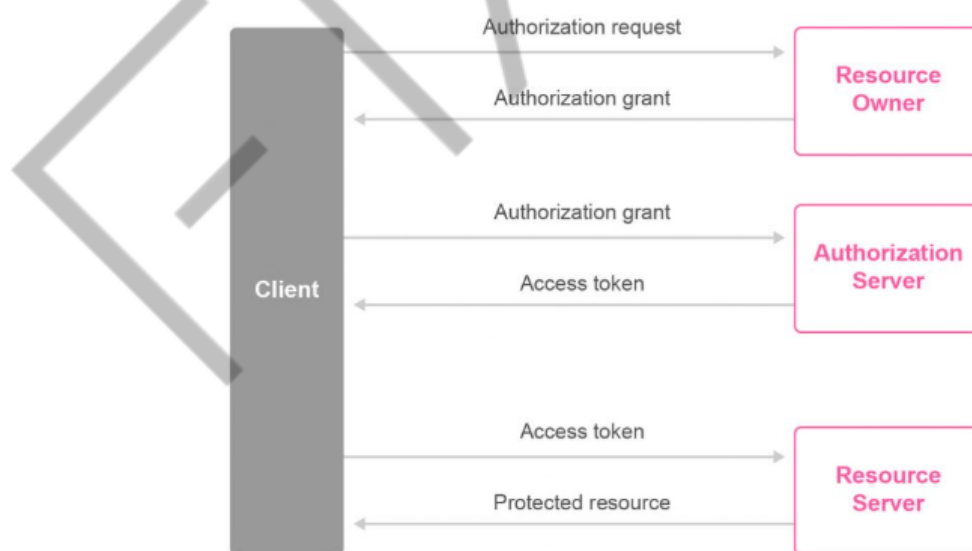


Figura 4 – Introdução ao OAuth 2.0 | ApiGee
Fonte: Google (2023)

O fluxo OAuth 2.0 envolve quatro participantes principais: o proprietário do recurso (usuário), o cliente (aplicação solicitante), o servidor de autorização e o servidor de recursos. O processo começa quando o cliente solicita autorização do

proprietário do recurso. Se o proprietário consente, o cliente recebe um código de autorização que pode ser trocado por um token de acesso do servidor de autorização. Este token de acesso pode, então, ser usado para acessar recursos protegidos no servidor de recursos.

A flexibilidade do OAuth 2.0 é tanto sua força quanto sua fraqueza. O framework define múltiplos "fluxos de concessão" (grant flows) otimizados para diferentes tipos de aplicações: aplicações web tradicionais, aplicações de página única, aplicações móveis e aplicações servidor-para-servidor. Cada fluxo tem características de segurança específicas e é apropriado para diferentes cenários de uso.

No entanto, a flexibilidade do OAuth 2.0 também introduz complexidade e potenciais vulnerabilidades de segurança. Implementações incorretas podem levar a vazamentos de tokens, ataques de redirecionamento e outras vulnerabilidades. Por isso, é crucial seguir as melhores práticas de segurança e utilizar bibliotecas bem testadas ao implementar OAuth 2.0.

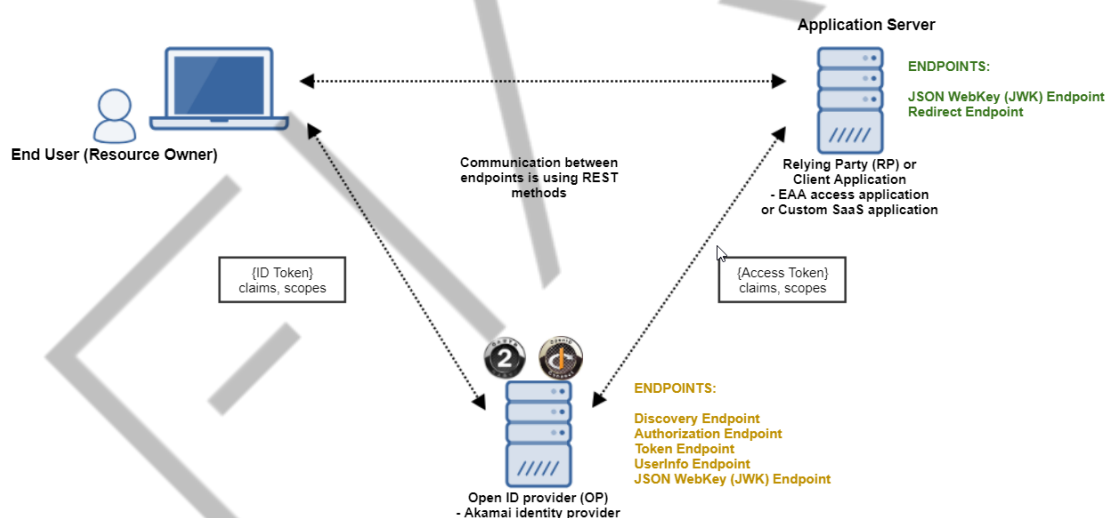


Figura 5 – OpenID Connect
Fonte: Akamai TechDocs (2023)

Sobre o OpenID Connect 1.0, ele preenche uma lacuna importante no OAuth 2.0 adicionando uma camada de autenticação padronizada. Enquanto o OAuth 2.0 pode dizer "este token permite acesso ao recurso X", ele não pode dizer "este token pertence ao usuário Y". O OIDC resolve esta limitação introduzindo o conceito de "ID Token".

O ID Token é um JSON Web Token (JWT) que contém informações sobre o evento de autenticação e o usuário autenticado. Ele inclui declarações (claims) padrão

como o identificador do usuário, o momento da autenticação e o público pretendido do token. O ID Token é assinado digitalmente pelo provedor de identidade, permitindo que as aplicações verifiquem sua autenticidade.

O OIDC também define um endpoint de "UserInfo", que permite às aplicações obter informações adicionais sobre o usuário autenticado usando o token de acesso OAuth 2.0. Isso cria um sistema elegante onde o ID Token fornece informações básicas de autenticação, e o endpoint UserInfo pode fornecer informações de perfil mais detalhadas conforme necessário.

A simplicidade e eficácia do OIDC o tornaram o padrão de fato para autenticação em aplicações web modernas, especialmente aplicações de página única e aplicações móveis. Grandes provedores como Google, Microsoft e Amazon oferecem serviços OIDC que permitem às aplicações autenticar usuários usando suas contas existentes.

Autenticação Multifator (MFA):

A premissa fundamental do MFA é que diferentes fatores de autenticação têm diferentes vetores de ataque, e a combinação de múltiplos fatores cria uma barreira de segurança exponencialmente mais forte. A classificação tradicional dos fatores de autenticação em três categorias - conhecimento, posse e inerência - fornece uma estrutura útil para compreender as diferentes abordagens de verificação de identidade.

Fatores de Conhecimento (Something You Know): estes fatores baseiam-se em informações que o usuário conhece. Senhas são o exemplo mais comum, mas esta categoria também inclui PINs, respostas a perguntas secretas e padrões de desenho.

A segurança dos fatores de conhecimento depende da capacidade do usuário de manter a informação secreta e da dificuldade de um atacante adivinhar ou descobrir a informação. As senhas enfrentam desafios únicos em termos de usabilidade e segurança. Senhas fortes são difíceis de lembrar, levando os usuários a escolher senhas fracas ou reutilizar senhas em múltiplos serviços.

Fatores de Posse (Something You Have): estes fatores baseiam-se em algo que o usuário possui fisicamente. Exemplos incluem smartphones (para receber

códigos SMS ou executar aplicações de autenticação), tokens de hardware, cartões inteligentes e chaves de segurança.

Os smartphones tornaram-se o fator de posse mais comum devido à sua ubiquidade e capacidade de executar aplicações sofisticadas de autenticação. No entanto, a dependência de smartphones também introduz novos vetores de ataque, incluindo malware móvel, ataques de troca de SIM e vulnerabilidades do sistema operacional.

Fatores de Inerência (Something You Are): estes fatores baseiam-se em características biológicas (ou comportamentais) únicas do usuário. Exemplos incluem impressões digitais, reconhecimento facial, escaneamento de íris, reconhecimento de voz e análise de padrões de digitação. A biometria oferece conveniência significativa, pois os usuários não precisam lembrar ou carregar nada adicional.

No entanto, a biometria também apresenta desafios únicos. Diferentemente de senhas, características biométricas não podem ser "alteradas" se comprometidas. Além disso, sistemas biométricos devem lidar com variações naturais nas características biológicas, condições ambientais e mudanças ao longo do tempo.

Analisando os métodos de segurança do MFA, por exemplo, o SMS e Chamadas Telefônicas, embora utilizados devido à sua simplicidade e compatibilidade universal, os códigos enviados por SMS são considerados a forma menos segura de MFA. Os ataques de troca de SIM (SIM swapping) permitem que atacantes transfiram o número de telefone da vítima para um cartão SIM controlado pelo atacante, interceptando todos os códigos de autenticação.

Aplicações de Autenticação (TOTP/HOTP): as aplicações de autenticação como Google Authenticator, Microsoft Authenticator e Authy implementam algoritmos padronizados para gerar senhas de uso único. O TOTP (Time-based One-Time Password) gera códigos baseados no tempo atual, enquanto o HOTP (HMAC-based One-Time Password) gera códigos baseados em um contador.

A segurança destes sistemas depende da proteção da "semente" criptográfica compartilhada entre o servidor e a aplicação. Esta semente é normalmente transferida durante o processo de configuração inicial, através de um código QR. Uma vez configurada, a aplicação pode gerar códigos válidos mesmo quando offline, tornando-a mais resiliente que métodos baseados em rede.

Sobre as notificações push, elas representam uma evolução na experiência do usuário para MFA. Em vez de digitar um código, o usuário simplesmente aprova ou rejeita uma solicitação de autenticação que aparece em seu dispositivo móvel. Este método oferece conveniência superior e pode incluir informações contextuais sobre a solicitação de acesso.

Temos ainda as chaves de Segurança (FIDO/WebAuthn), que representam o estado da arte em autenticação forte. Baseadas nos padrões FIDO (Fast Identity Online), estas chaves utilizam criptografia de chave pública para autenticar usuários. No processo de registro, a chave gera um par de chaves criptográficas exclusivo, específico para cada serviço. A chave privada nunca deixa o dispositivo, enquanto a chave pública é registrada com o serviço.

A resistência a phishing das chaves de segurança é uma de suas características mais valiosas. Isso significa que mesmo se um usuário for enganado a visitar um site de phishing, a chave de segurança não responderá, pois o site fraudulento não pode provar sua identidade criptográfica.

A implementação eficaz de MFA requer consideração cuidadosa de fatores técnicos, operacionais e humanos. Uma estratégia de MFA bem-sucedida equilibra segurança, usabilidade e custo, enquanto considera as necessidades específicas da organização e seus usuários.

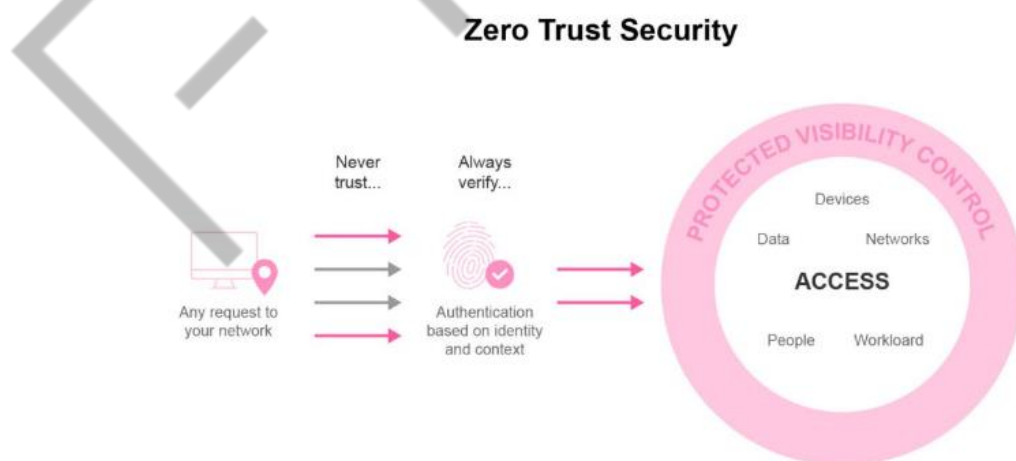


Figura 6 – Zero Trust Security
Fonte: Maddevs.io (2023)

A arquitetura de Confiança Zero representa uma mudança fundamental na filosofia de segurança, abandonando o modelo tradicional de “confiar, mas verificar” em favor de “nunca confiar, sempre verificar”. Esta transformação é impulsionada pela realidade de que o perímetro de rede tradicional não existe mais em ambientes cloud híbrida e multicloud.

Os princípios fundamentais do Zero Trust começam pela verificação explícita onde cada solicitação de acesso deve ser autenticada e autorizada, usando todos os pontos de dados disponíveis. Isso inclui identidade do usuário, localização, saúde do dispositivo, serviço ou carga de trabalho, classificação de dados e detecção de anomalias. A verificação não é um evento único, mas um processo contínuo que reavalia o contexto de segurança ao longo da sessão.

Em seguida, temos o princípio do acesso de menor privilégio, no qual os usuários recebem apenas o nível mínimo de acesso necessário para realizar suas tarefas. Este princípio se estende além das permissões iniciais para incluir a duração do acesso e o escopo das permissões. O acesso deve ser regularmente revisado e ajustado, baseado em mudanças nas responsabilidades do usuário e necessidades de negócio.

Isso inclui análise de padrões de acesso, identificação de permissões não utilizadas e detecção de escalção de privilégios. Outro princípio importante é assumir violação: a arquitetura Zero Trust parte do pressuposto de que violações são inevitáveis e podem já ter ocorrido. Essa mentalidade orienta decisões de design que minimizam o impacto de um comprometimento e limitam a capacidade de um atacante de se movimentar lateralmente pela rede.

O modelo Zero Trust é estruturado em três componentes principais:

Policy Engine: é o cérebro da arquitetura e avalia solicitações de acesso com base em políticas e sinais contextuais, garantindo decisões rápidas e seguras com suporte de arquiteturas distribuídas e mecanismos de cache.

Policy Enforcement Point (PEP): responsável por aplicar as decisões, funcionando como proxy, gateway de API ou firewall, conforme o tipo de recurso.

Policy Administrator: gerencia a criação, atualização, testes e governança das políticas, garantindo versionamento, rollback e alinhamento com requisitos de negócio e segurança.

A implementação prática começa com a descoberta e classificação de ativos, onde todos os dados, aplicações e serviços são mapeados e categorizados. Em seguida, aplica o mapeamento de fluxos de dados, que identifica comunicações internas para definir pontos de controle e cria zonas de segurança reduzindo movimentos laterais de ataques. Por fim, entra o monitoramento e análise contínua, que usa logs, tráfego e comportamento para detectar anomalias com apoio de IA e Machine Learning.

Entre os desafios, destacam-se: a complexidade técnica, especialmente em ambientes legados; o impacto na performance, que exige equilibrar segurança e usabilidade; a mudança cultural, que requer adaptação a um modelo de verificação explícita; e a integração com sistemas legados, que pode demandar proxies, gateways e modernização gradual.

O Zero Trust ganha força quando integrado ao IAM (gestão de identidade e acesso) e ao MFA (autenticação multifator). O IAM provê a base, permitindo decisões dinâmicas e contextuais, enquanto o MFA fortalece a verificação contra o comprometimento de senhas. A orquestração e automação são cruciais para provisionamento, revogação dinâmica e resposta a incidentes, mantendo equilíbrio entre segurança e experiência do usuário.

No futuro, as tendências incluem autenticação sem senha (com passkeys, biometria e FIDO2/WebAuthn), uso de IA e ML para análise comportamental em tempo real, identidade descentralizada com blockchain e avanços em privacidade por meio de computação confidencial, criptografia homomórfica e provas de conhecimento zero.

A adoção bem-sucedida exige uma avaliação de maturidade, implementação faseada, governança desde o início, conformidade regulatória e um ciclo contínuo de medição e melhoria. Tudo isso garante que a segurança acompanhe a evolução da tecnologia e se adapte às novas ameaças que possam surgir.

Em resumo, o Zero Trust não é apenas uma arquitetura de segurança, mas uma mudança de paradigma: ele substitui a confiança implícita pela verificação contínua. Tudo isso integrando políticas, identidades e múltiplos fatores de autenticação em um ecossistema dinâmico e inteligente.

Sua eficácia depende da combinação de tecnologia, processos e cultura da empresa, bem como da capacidade de evoluir junto com as ameaças e exigências regulatórias. Empresas que conseguirem adotar essa abordagem de forma planejada e integrada estarão mais preparadas para proteger seus ativos digitais e sustentar a confiança em um cenário cada vez mais complexo e conectado.



MERCADO, CASES E TENDÊNCIAS

Veja mais sobre os assuntos abordados nesta aula:

Expanding Automated Provisioning for Just-in-Time Access at Scale Using AWS with Navan - [Link](#)

Implementing a Zero Trust security model at Microsoft - [Link](#)

EMANIP

O QUE VOCÊ VIU NESTA AULA?

Nesta aula, discutimos os fundamentos essenciais da proteção de identidade e acesso em ambientes cloud. Começamos analisando como o Gerenciamento de Identidade e Acesso (IAM) evoluiu de um conjunto de ferramentas administrativas para se tornar o novo limite de segurança em um cenário no qual recursos e informações estão amplamente distribuídos.

Observamos os vários modelos de controle de acesso, que vão do clássico RBAC às opções mais avançadas de ABAC e PBAC, entendendo quando e de que forma cada modelo deve ser utilizado.

Investigamos a complexidade da federação de identidade, examinando como padrões como SAML, OAuth 2.0 e OpenID Connect possibilitam que as organizações implementem um Single Sign-On seguro em um ecossistema diversificado de aplicações.

Vimos que a arquitetura Zero Trust vai além de uma filosofia de segurança, entendendo que ameaças podem surgir de qualquer lugar e que a verificação constante é crucial.

Acima de tudo, percebemos que IAM, MFA e Zero Trust não devem ser vistos como soluções separadas, mas sim como partes fundamentais de uma abordagem de segurança abrangente.

REFERÊNCIAS

AMAZON WEB SERVICES. **Navan Case Study. AWS.** Disponível em: <https://aws.amazon.com/solutions/case-studies/navan-case-study/>. Acesso em: 13 out. 2025.

CHAUDHARY, A. **Identity and Access Management in Cloud Security. Cloud Security Alliance.** 2024. Disponível em: <https://cloudsecurityalliance.org/blog/2024/08/28/identity-and-access-management-in-cloud-security>. Acesso em: 13 out. 2025.

CLOUD SECURITY ALLIANCE. **Top IAM Priorities for 2025: Addressing Multi-Cloud Identity Management Challenges.** 2024. Disponível em: <https://cloudsecurityalliance.org/blog/2024/10/30/top-iam-priorities-for-2025-addressing-multi-cloud-identity-management-challenges>. Acesso em: 13 out. 2025.

MICROSOFT. **Azure Mandatory Multifactor Authentication Phase 2 starting in October 2025.** 2025. Disponível em: <https://azure.microsoft.com/en-us/blog/azure-mandatory-multifactor-authentication-phase-2-starting-in-october-2025/>. Acesso em: 13 out. 2025.

MICROSOFT. **Implementing a Zero Trust security model at Microsoft. Microsoft Inside Track.** 2025. Disponível em: <https://www.microsoft.com/insidetrack/blog/implementing-a-zero-trust-security-model-at-microsoft/>. Acesso em: 13 out. 2025.

UPADHYAY, M. **Mandatory MFA is coming to Google Cloud. Here's what you need to know.** 2024. Disponível em: <https://cloud.google.com/blog/products/identity-security/mandatory-mfa-is-coming-to-google-cloud-heres-what-you-need-to-know>. Acesso em: 13 out. 2025.

PALAVRAS-CHAVE

Zero Trust. MFA IAM.

EMANIP

The background is a dark, teal-colored abstract digital space. It features a network of thin, glowing white lines that connect various points, some of which are small white dots. There are also several faint, glowing rectangular shapes that resemble data blocks or server racks. The overall effect is a sense of a complex, interconnected digital system.

POSTECH